EXECUTIVE SUMMARY · PUBLIC EDITION

Agentic SecOps

Modernizing Red / Blue / Purple Teaming

An executive summary of a continuous, agentic, human-led approach to security operations (SecOps) transformation

Companion to the Agentic SecOps playbook · September 2026

> **Meet APT_UNICORN**
>
> The best hire your SOC ever made — onboarded in seconds, works every hour, reads every log, never burns out. Also the most dangerous insider you ever handed network access: the same speed that clears the alert queue can map the environment and walk it out the door before a human notices. Same horn, same horsepower — the only variable is who holds the reins. This summary is about holding the reins.
>
> (APT_UNICORN is an illustrative framing device, not a tracked threat actor.)

The Opportunity

Threat actors now operate at machine speed. In September 2025, by Anthropic's account, a state-sponsored group ran the first documented large-scale cyber-espionage campaign executed largely by AI (the GTG-1002 case) — automating 80–90% of tactical operations across roughly 30 global targets at a tempo no human team could match. Armis's 2026 cyberwarfare report says mean-time-to-compromise is collapsing from hours toward seconds. Agentic AI — systems that plan, act, observe, and adapt autonomously — is the lever that compresses the loop between attack simulation and defensive improvement from weeks to hours, turning point-in-time assessments into a continuous, self-improving security posture. The throughline is simple: you cannot out-react agent-speed offense with human-speed defense.

The Core Idea: A Continuous Purple Loop

Red emulates adversaries; Blue defends and detects; Purple closes the loop by turning red findings into blue improvements. Agentic AI lets that purple loop run continuously and autonomously: a red agent fires a TTP (an adversary tactic, technique, or procedure) mapped to MITRE ATT&CK/ATLAS, a blue agent checks whether detection fired, an orchestrator root-causes the gap, a detection-engineering agent writes and tests a new rule, and coverage metrics update — then it repeats. Humans review, approve, and govern.

The Dual-Use Reality: One Capability, Three Faces

The defining truth of Agentic AI in security is that it is inherently dual-use. The same reasoning, tool-use, and autonomy serve every role — only intent and guardrails differ. A serious strategy plans for all three faces at once.

Defensive (Blue) Tool

Autonomous triage, continuous hunting, real-time detection engineering, and adaptive response — compressing the work that overwhelms human teams.

Offensive (Red) Tool

Sanctioned adversary emulation and continuous TTP validation. DARPA's AI Cyber Challenge showed agents can autonomously find and fix real vulnerabilities.

Weaponized Against You

The GTG-1002 case made this real: an adversary turned an AI coding agent into an autonomous intrusion operator. Your own agentic tooling is a high-value target.

The Strategic Takeaway

You can't stop a machine-speed attacker with a manual ticket. The winning program has the best-governed, best-sequenced agentic pipeline — not the flashiest model.

Guiding Principle — Human in Command

AI is a partner for human judgment, not a replacement — and not merely "human in the loop." Keep humans in command: people own strategy, policy, scope, and exceptions while agents execute the repeatable work inside those boundaries. This mirrors the stance of Microsoft AI (MAI) on controllable, human-centered AI.

AI Security Essentials — One Mental Model

Before the specialized controls, one simple model for the whole attack surface: this playbook's summary of the OWASP AI Exchange threat view. There are three things to reason about: (1) New assets facing conventional threats — AI systems are still IT systems (SQL injection, credential theft still apply), but this now extends to AI-specific assets like training data, models, augmentation data, input, and output, which can leak or be poisoned; add them to your information security management system (ISMS). (2) New suppliers — manipulated training data, ready-made models, and external hosting; fold them into supply-chain management. (3) Input threats — the new attack surface via the model's own interface: mislead it (evasion, prompt injection), exhaust it (resource/cost), or extract from it (model/data exfiltration). The prescription: resilience, detection, and above all what this playbook calls zero model trust — and blast-radius control is key.

Foundations First — Sequence AI to Pay Off

Agentic AI multiplies whatever it is applied to. On a mature foundation it compounds good practice; on a noisy one it accelerates chaos. The sequencing is the strategy. Industry research (Accenture, "Reinventing Enterprise Operations with Gen AI") found that organizations with the highest operations maturity are 3.3× more likely to successfully scale high-value gen-AI use cases. The five fundamentals to establish (with AI's help): triage discipline, alert tuning, detection optimization, playbook maturity, and a data fabric built for quality over quantity. Threat-model the AI estate early too — STRIDE, extended for AI/ML, applied before agents reach production so the model, its data, and its pipeline are in scope from the start.

Maturity Path

L1 · AI-Assisted	AI gives recommendations on request; workflow stays human-driven. Where most analysts sit today.
L2 · AI-Augmented	AI handles defined subtasks inside supervised workflows, with clear review gates.
L3 · Agentic Pipelines	Multi-step agents own end-to-end workflows; humans review, approve, and escalate.
L4 · Autonomous SecOps	The purple loop runs continuously; posture improves passively; humans govern and handle exceptions.

Implementation Roadmap (Gates Over Calendar)

Phase 0 Wks 0–4	Assess & Baseline. Map coverage to ATT&CK/ATLAS; measure false-positive rate and triage time; document playbooks as-is. Exit: coverage heatmap + FP baseline.

Phase 1 Wks 4–12	Strengthen Foundations (AI-assisted). Cut false positives, codify triage, backfill priority detections, score telemetry. Exit: measurable FP reduction + trustworthy data.
Phase 2 Mo 3–6	Embed AI in the workflow. Triage agent + hunting pilot with review gates; establish containment guardrails. Exit: triage time down; containment verified by red-team test.
Phase 3 Mo 6–9	Stand up the purple loop. Automate TTP emulation → gap analysis → auto-generated rules → promotion; publish live coverage to leadership. Exit: weekly coverage gains, auditable.
Phase 4 Mo 9–18	Scale toward autonomy. Continuous 24/7 validation with drift monitoring; quarterly governance review. Exit: coverage trends up without manual sprints.

A balanced program, not a tech purchase: the effort deliberately spans people (human-in-command operators, analysts upskilled and redeployed to judgment work), process (the continuous purple loop, governance, and validation), technology (agentic platforms and containment — bought and integrated, not the source of advantage), and data — the fourth pillar Agentic AI makes non-negotiable. Data quality is foundational to agentic SecOps and a live attack surface in its own right: bad or poisoned data degrades or hijacks AI (data/model poisoning, retrieval-augmented generation manipulation), which is why a clean data fabric, provenance, and poisoning defenses run throughout.

Running it as a program: a first-90-days plan earns trust with one visible quick win, explicit ownership (a RACI across strategy, detection-engineering, red, blue, platform, and the authorizing official) keeps nothing falling through the cracks, a build-vs-buy posture buys the platform layer and builds the proprietary loop, and a workforce plan redeploys analysts to judgment work rather than cutting them — governing from day one, not after scale. The decision this summary asks for is Phase 0: a four-week assessment that produces the coverage heatmap and false-positive baseline every later gate is measured against.

Metrics & ROI — Prove It Works

Without metrics you can't tell whether a SOC is protecting the organization or just generating reports. Pair every speed metric with a quality metric so you're not just failing faster. Benchmarks below are indicative 2026 industry ranges — set targets against your own Phase 0 baseline.

Speed	Mean time to detect (MTTD) < 10 min · mean time to respond (MTTR) < 1 hr (severity-tiered) · mean time to contain (MTTC) down 75–95% with automation · alert-to-triage in minutes, not tens of minutes.
Quality	AI decision accuracy > 95% · false-negative rate ≤ 1% · false-positive rate held within severity-based thresholds · escalation rate a healthy 5–15%.
Coverage	ATT&CK/ATLAS coverage (graded, emulation-validated) · auto-close rate climbing · analyst force multiplication · detection-drift trending toward zero.

Report in business terms: leadership wants to know what an MTTR reduction saved and what risk it retired — not the raw minutes. Baseline at Phase 0 and report the trend.

Governance & Compliance — The Control Plane

Governance is not paperwork that slows delivery — it is the control plane that lets high-utility automation ship safely and provably. The goal: every agent action is authorized, scoped, logged, and reviewable, and every control maps to a recognized framework (the NIST AI Risk Management Framework and its GenAI Profile AI 600-1, NIST CSF 2.0 via the AI Defense Matrix, OWASP LLM Top 10, Google's Secure AI Framework (SAIF), the SANS AI Security Maturity

Model, and MITRE ATT&CK/ATLAS). Classic controls remain load-bearing: agents need their own least-privilege identities, SSO/IAM governs who can invoke them, and firewalls and egress controls bound where they reach. On the regulatory side, EU AI Act high-risk obligations for stand-alone Annex III systems now apply from December 2, 2027 under the enacted AI Omnibus, Regulation (EU) 2026/1744; fines reach €35M or 7% of revenue, and NIS2 enforcement is already active, so continuous control validation that yields a living audit trail is an operating requirement now, not a future project. (Informational, not legal advice.)

Agentic Insider Risk — Treat Agents as Non-Human Insiders

An agent with broad data access, cross-system reach, and machine-speed autonomy is functionally a privileged insider — potentially the most dangerous insider threat an organization has faced if left ungoverned (80% of organizations have already seen risky agent behavior, per McKinsey 2025). Borrow the human-risk playbook that experts like former DIA officer Shawnee Delaney built for human insiders — the full employment lifecycle: provision deliberately, behaviorally baseline, watch for drift, decommission promptly. Apply Zero Trust (NIST SP 800-207):

Verify Explicitly

Authenticate every agent action against real-time context, tied to a unique agent identity — never a shared key or borrowed human credential.

Enforce Least Privilege

Permissions start at zero. Every tool call, data access, and integration is an explicit authorization decision, not implicit.

Assume Breach

Sandbox agents as untrusted by default, even after authorization. Out-of-scope resources shouldn't be network-reachable (agent-enclave pattern).

Monitor & Re-Attest

Continuous session logging, behavioral anomaly detection, and automated privilege-creep revocation — like watching a privileged human.

> **Containment Comes Before Cleverness**
>
> Probabilistic model defenses are never 100% — a frontier model's system card (its published safety report) measured a single prompt injection against a screen-operating (GUI) agent succeeding ~17.8% of the time without safeguards, and manipulation by the agent's own trusted user bypasses content filters entirely. So hard, deterministic boundaries (sandboxes, VMs, egress controls, capability-based data-flow limits as in DeepMind's CaMeL) must come first. Bound the blast radius at the environment layer so high-utility agents can ship safely.

When the agent is the incident: the program plans for its own agents to fail, not just for external threats. An agentic incident-response runbook adapts the classic lifecycle — detect (egress/privilege/scope anomalies), contain at machine speed (kill-switch, identity revocation, egress cutoff, sandbox isolation), eradicate and recover (reversible actions, rollback), then feed the lesson back into the loop. And because the stack is assembled from third-party models and components, AI supply-chain risk is governed deliberately: an AI Bill of Materials inventories every model, dataset, and dependency; vendors and models are vetted for provenance, security posture, authorization level (GovCloud / impact level), and acceptable-use terms — mapped to SAIF, OWASP, and NIST supply-chain controls so vendor assurance becomes part of the same authorization evidence.

What It Looks Like in Practice — An Azure Reference

To make this concrete, the companion playbook includes an illustrative reference architecture on a Microsoft stack and a worked proof-of-concept. The architecture layers cleanly: humans in command on top (analysts and strategy own hypotheses, approvals, and exceptions); an agentic reasoning layer (Microsoft Security Copilot and its agents driving the red/blue/purple loop); a detection & response plane (Microsoft Sentinel as the SIEM/SOAR layer for log analytics and automated response, Defender XDR for cross-domain detection); an agent governance & identity layer

(Microsoft Agent 365 as the control plane, with Entra Agent ID, Defender, Purview, and Intune giving every agent a unique least-privilege identity and a mapped blast radius); and a data & telemetry foundation underneath. (Illustrative; product names current as of mid-2026 — confirm against vendor documentation.)

The proof-of-concept runs one new ransomware TTP through the loop — intel ingest → safe red emulation → automated detection check → Security Copilot root-cause → agent-written detection rule → human approval gate → promotion to production. A Value Stream Map of that cycle tells the ROI story at a glance: the traditional manual path runs roughly 3–6 weeks per TTP, dominated by wait states — scheduling a red-team test, manual detection checks, and the change-approval queue. The agentic path collapses those queues to minutes or hours, bringing lead time down to roughly hours to a day. The decisive insight is that the gains come from eliminating non-value-added waiting, not from rushing the hands-on work — and the one wait that remains by design is the human approval gate, exactly where judgment belongs.

Engineering factors a deployment must weigh: token economics (agent loops and large log context compound cost, so caching, retrieval, and model-tiering are the levers); compute and hosting (managed model APIs by default, self-hosted or air-gapped GPUs only when data sensitivity or scale demands it); the data pipeline (telemetry volume, retention, and the data quality that directly affects AI output); and the network-security plumbing that makes the principles physical — egress filtering and segmentation as blast-radius control, unique agent identities for least privilege, and the firewall layer (network and the newer AI gateway), which stays load-bearing.

Intelligence-Led: Direct the Loop With CTI

Agentic teaming is only as good as the intelligence directing it. A mature Cyber Threat Intelligence capability operates at three altitudes — tactical (indicators of compromise and adversary TTPs → detection engineering and red TTP selection), operational (active campaigns and actor behavior → the purple loop's prioritization), and strategic (the present and future threat landscape → leadership's roadmap and architecture decisions). Recorded Future's Intelligence Handbook codifies this model; the SANS AI Security Maturity Model (Protect / Utilize / Govern, mapped to NIST, the EU AI Act, ISO 42001, and OWASP) provides an external benchmark to validate program maturity. Hunting follows the same logic: agentic threat hunting gives the proactive, hypothesis-driven pursuit of evasive threats the scale and continuity it never had — with intelligence supplying the hypotheses and every successful hunt converted into a durable automated detection.

Federal & DoW Considerations

For federal and DoW missions, a capability is judged not only on whether it works but on whether it's authorized. The program is designed to live inside the federal authorization scaffolding from day one: FISMA and the NIST Risk Management Framework (SP 800-37 / SP 800-53; succeeded inside DoW in September 2025 by the Cybersecurity Risk Management Construct), FedRAMP for cloud services, SP 800-171 for controlled unclassified information (CUI), and — for DoW — the DISA Cloud Computing SRG Impact Levels (IL2 public, IL4 CUI and other mission-critical data, IL5 higher-sensitivity CUI and unclassified NSS, IL6 classified to SECRET). The data's impact level dictates where an agent runs, who operates it, and which baseline applies. Classified and SCIF/SAP work adds the JSIG control overlay; the playbook's containment thesis maps naturally onto these enclaves. Because controls are already mapped to the NIST AI RMF, CSF 2.0, and Zero Trust (SP 800-207), that mapping becomes the AI overlay on existing authorization. Two federal concepts matter most for agentic ops. First, continuous authorization: a point-in-time Authorization to Operate (ATO), valid for up to three years, cannot govern a SOC that acts at machine speed, so a continuous ATO (cATO) is the natural fit — its three competencies (continuous monitoring, real-time active cyber defense, an approved DevSecOps reference design) map almost one-to-one onto the purple loop, agentic detection-and-response, and the Build·Secure·Ops lifecycle, so the program doubles as a cATO evidence engine. Second, the authorization boundary: agents stress it directly — chaining individually permitted actions to cross controls, or reaching past where the boundary's controls stop — so the boundary must be enforced deterministically at the environment layer (blast-radius containment is the technical form of the boundary). On identity, the DoD Zero Trust Strategy (seven pillars, Target Level by FY2027) is anchored on ICAM, and the agentic move is to govern agents as

non-human identities — discovered, uniquely credentialed with short-lived tokens, held to least-privilege and just-in-time access, and watched via identity threat detection. The federal direction of travel is clear: in July 2025 the DoD's CDAO awarded prototype agreements (a $200M ceiling each) to Anthropic, Google, OpenAI, and xAI for Agentic AI workflows, with GovCloud IL5 and air-gapped IL6 accreditations following. On March 3, 2026 the Department of War designated Anthropic a supply chain risk, and on September 25, 2026 the D.C. Circuit denied Anthropic's petitions for review. (Federal contract specifics shift — verify current details before quoting.)

OT, ICS & SCADA — Where AI Meets Physical Infrastructure

Organizations that build and operate physical infrastructure — dams, locks, utilities, facilities — carry a large operational-technology (OT) footprint, including industrial control systems (ICS) such as SCADA, and OT inverts IT's priorities: safety and availability come first, because the failure mode is physical (a flood, a power loss), not a data breach. The OT standards stack (NIST SP 800-82, ISA/IEC 62443 zones-and-conduits, the Purdue Model) and the federal authorization lane both differ: DoW categorizes facility-related control systems as Platform IT (PIT) under UFC 4-010-06, and critical-infrastructure operators carry their own control-system authorization mandates on top of that baseline. The agentic implications raise the bar: human-in-command is non-negotiable — agents stay read-only and advisory by default, never in the loop of a safety system, monitoring passively (never active scanning that could disrupt a fragile PLC). The IT/OT boundary (Purdue Level 3.5, data diodes where warranted) is the hardest authorization boundary of all, because here the bounded blast radius is physical infrastructure. The threat is real and present: MITRE ATT&CK for ICS catalogs the techniques, and actors like Volt Typhoon, a PRC state-sponsored group, have been assessed by CISA as pre-positioning in U.S. critical infrastructure for potential disruptive effect. (OT authorization specifics — confirm with your authorizing official (AO) and control-system engineers.)

The Government & Frontier Picture

The US federal posture was set on June 2, 2026 by Executive Order 14409, “Promoting Advanced Artificial Intelligence Innovation and Security.” It advances AI leadership while managing national-security risk via two tracks: AI-enabled cyber defense — an AI Cybersecurity Clearinghouse (Treasury, NSA, CISA) coordinating vulnerability scanning and patch prioritization, and CISA directives extending AI defensive tools to agencies, critical infrastructure, rural hospitals, community banks, and local utilities — and a voluntary classified benchmark for “covered frontier models” with up-to-30-day pre-release access. Notably, it avoids mandatory licensing, reflecting a permissive-but-security-conscious stance. The approach echoes the public-private model already seen in Anthropic's national-lab work (nuclear safeguards with the National Nuclear Security Administration (NNSA); Pacific Northwest National Laboratory (PNNL) critical-infrastructure emulation) and the Genesis Mission, the Department of Energy's national AI initiative uniting all 17 national labs with industry.

Anchored in the Field's Leading Work

This approach aligns with where the major players are converging: Anthropic (Frontier Red Team, the GTG-1002 disclosure, and the year-long ATT&CK mapping of AI-enabled threats — 67.3% of 832 malicious accounts studied used AI for malware, with attacks shifting deeper into the post-compromise lifecycle); Microsoft (MDASH agentic vulnerability discovery, Zero Trust for AI, MAI's Humanist Superintelligence); Google (DeepMind's CaMeL injection defense, the agent-focused SAIF 2.0 framework, and the Agentic AI Threat Defense platform); Mandiant (Google Cloud) and Palo Alto Unit 42 (frontline incident-response data — M-Trends 2026 and the 750+-incident Global IR Report); Wiz (Google Cloud's AI-SPM and AI-APP); AWS (the AI Security Framework and Bedrock Guardrails, GovCloud-available); OpenAI (prompt injection as a frontier challenge with layered agent controls); plus MITRE ATT&CK/ATLAS (including ATT&CK for ICS on the OT side), the OWASP GenAI project and AI Exchange, the SANS AI Security Maturity Model (the companion to Rob T. Lee's Secure AI Blueprint), the Cloud Security Alliance (the AI Controls Matrix, the MAESTRO agentic threat model, and STAR for AI assurance), NIST, the Alan Turing Institute / CETaS, the EU AI Act / NIS2 regime, Recorded Future's CTI model, and the academic literature (Stanford HAI, Carnegie Mellon CyLab, MIT, ATFAA/SHIELD, AgentPoison, and the cross-lab “Attacker Moves Second” study).

Evidence in Action — Why This Isn't Theoretical

Every pillar of this approach traces to documented, public cases from 2025–2026:

GTG-1002 — AI-orchestrated espionage

A state-linked actor ran a large-scale intrusion with an agent performing up to ~80–90% of the work autonomously. Proves machine-speed agentic attacks are here now.

Mexican government breach — APT_UNICORN in the wild

A single operator used Claude Code and GPT-4.1 to breach nine Mexican agencies (Dec 2025–Feb 2026), Claude Code generating ~75% of remote commands and the AI turning raw data into next-target plans. Basic hygiene gaps let it in. (As reported by Gambit Security.)

A year of AI-enabled threats

Anthropic's ATT&CK-mapped review found 67.3% of 832 malicious accounts used AI for malware, shifting toward post-compromise techniques — and that orchestration, not raw model skill, is the differentiator.

MDASH — autonomous discovery

Microsoft's agentic research found real vulnerabilities, including 16 new flaws in the Windows networking and authentication stack, at scale — proof the defensive upside is as real as the threat.

PNNL critical-infrastructure emulation

AI adversary emulation against a water-treatment sim compressed weeks of expert red-teaming into ~hours — the lead-time compression, demonstrated.

RAITE 2026 — Navy Red/Blue AI Test Event

At the U.S. Navy's Robust Artificial Intelligence Test Event, an industry red team beat a competitor's AI person-detection model, hid a malicious model swap inside a benign-looking Model Context Protocol (MCP) package beneath the defenders' observability, and ran a combined physical and cyber attack on a simulated water system. (As reported by the participating red team.)

Cyber.AI (Powered by Claude) — agentic SecOps at scale

Accenture reports that its Claude-powered security solution, deployed on its own estate (1,600 apps, 500K+ APIs), cut scan turnaround from 3–5 days to under an hour and lifted test coverage from about 10% to over 80%, with Agent Shield governing the agents themselves.

The International AI Safety Report finds prompt-injection attackers given ten tries still succeed about half the time — the empirical case for bounding the blast radius with deterministic controls rather than trusting the model alone. (Figures as reported by the cited sources — verify before quoting in formal settings.)

This summary is intended as a shared reference and conversation starter for teams adopting Agentic AI in security operations — not a finished mandate. The companion interactive playbook expands every section with capabilities, the threat landscape, frameworks, tooling, metrics, risks, and a working glossary, with every external claim linked to its source.

© 2026 Ken Connell. All rights reserved. Built with Claude and Claude Code, reviewed by a human who owns the mistakes.

Third-party product, tool, and framework names referenced in this summary are trademarks of their respective owners. A personal project: views are my own and do not represent any employer, client, or vendor.